

Access Controls Policy

Internal policy for a private, single-user personal finance application. This document describes how access to source code, credentials, and financial data is limited and reviewed.

Owner	Nolan Chu
Application	Private personal net worth tracker
Effective date	2026-03-19
Access model	Single authorized operator; least privilege; read-only financial data access where possible

1. Purpose and scope

- This policy defines the access controls used to protect production assets, source code repositories, API credentials, and financial data handled by the application.
- The policy applies to the application owner, any supporting infrastructure used to run scheduled jobs, and any third-party services used to connect to financial institutions.

2. Access principles

- Access is restricted to the minimum required to operate the application. Only the owner is authorized to access production assets and sensitive data.
- Shared credentials are not used. Administrative access is limited to named personal accounts controlled by the owner.
- Where available, read-only data access is preferred over permissions that can move money or modify external accounts.

3. Credential and secret management

- API keys, access tokens, and other secrets must not be committed to source control.
- Secrets are stored only in approved secret stores such as local environment files excluded from version control and private continuous-integration secret storage.
- If a credential is exposed or suspected to be exposed, it must be rotated as soon as practical and any affected sessions or tokens must be revoked when supported by the provider.

4. Non-human authentication

- Automated jobs authenticate to external services using provider-issued API keys, OAuth access tokens, or other provider-approved machine credentials.
- All application traffic to external APIs must use HTTPS with TLS 1.2 or better.
- Non-human credentials are scoped to the minimum available permissions needed for scheduled balance collection and reporting.

5. Access reviews and audits

- Access to repositories, CI secrets, provider dashboards, and connected financial accounts is reviewed periodically by the owner.
- At a minimum, the owner reviews active secrets, connected accounts, and repository access after material changes and no less than annually.
- Unneeded credentials, stale tokens, test accounts, and obsolete integrations are removed when identified.

6. MFA and account protection

- Multi-factor authentication is enabled on critical administrative accounts when supported, including source control, email used for account recovery, and provider dashboards.
- Administrative actions are performed from the owner's authenticated account only.

7. Logging and change control

- Changes to code and configuration are made through the private repository and its associated change history.
- The owner reviews workflow and secret changes before use in production.

8. Exceptions

- Because the application is operated by a single individual, certain enterprise controls such as RBAC, centralized identity systems, and automated employee de-provisioning are not applicable.
- Any future addition of collaborators or production systems must trigger a policy review and corresponding control updates.

Approval: This policy is maintained by the application owner and is reviewed periodically or when the architecture changes materially.